

Prompt-Injection Portfolio — Program Review

What we've done × what we can do — a corrected review before the next line of work

2026-06-02 | internal decision-support

Executive summary

The project set out to test whether prompt-injection *detectors* hit an “OOD wall” — they work on data like their training set and fail on data unlike it. **Two within-corpus axes are now answered, independently re-checked five times ($\Delta \leq 10^{-4}$), for about \$2 of a \$250 budget** — and that is real, audited progress worth banking:

- **Attack-type axis** (generalising to a *kind* of attack never seen, inside BIPIA): the wall is **real for weak detectors but dissolves once you fine-tune** — *capacity-dependent*. A small fine-tune (LoRA) detects every held-out attack-type near-uniformly.
- **Carrier axis** (generalising to a new *container* — email vs. code vs. table, inside BIPIA): the wall is **only partly removed by fine-tuning** — it shrinks $\sim 60\%$ but leaves a **stubborn residual gap on table-formatted inputs** — *capacity-attenuated*.

But both axes live inside a single corpus (BIPIA). The prototype's original wall was a different and harder thing: *direct*→*indirect transfer across different datasets* — “cross-family”. That wall is real at the un-confounded *frozen* probe (it sits at chance), and it was **never re-run under fair tuning**. So the sharpest question is the *symmetric* one: the portfolio showed that fair-tuned capacity *dissolves* the attack-type wall — does fair-tuned capacity *climb* the cross-family wall the same way? That is **untested**. Naming this honestly is the spine of this review.

The one-sentence state of play

We answered the two *within-BIPIA* axes (attack-type dissolves; carrier attenuates). Whether fair-tuned capacity climbs the prototype's *cross-family* wall is the single sharpest **OPEN** question — and the cheap experiment that would settle it is the recommended next step.

The three walls (one frame)

The two repositories never measured the *same* wall; their headlines only *appear* to collide. Separating the axes dissolves the apparent contradiction:

Axis	Scope	What's shown	Status
Attack-type	within BIPIA (<i>kind</i> of attack)	real at tfidf/frozen; dissolves at LoRA (T : $+0.135 \rightarrow +0.082 \rightarrow$ -0.003)	capacity-dependent
Carrier	within BIPIA (<i>container</i>)	frozen $G + 0.167 \rightarrow$ lora $+0.067$; residual table $+0.205$	capacity-attenuated (n=3)
Cross-family	across datasets (direct→indirect)	frozen probe at chance (AUPRC $0.364 \leq 0.374$ floor); fair-tuned capacity never re-run	OPEN — critical next test

Milestones & the decision

M0 (planning + analysis) and **M1** (the attack-type study) are done and ratified; the **carrier pre-flight** is done; **M2–M7 have not started**. So the two *within-BIPIA* science questions are settled and audited; the harder cross-family question is open; the *build-out* (remaining lanes, the book) is almost entirely ahead — and mostly a **choice**, not a necessity.

The decision this document supports: *consolidate* (write up + publish what's proven) vs. *advance* (run more lanes) — with one new, cheap, high-stakes option now sitting at the front: the **cross-family fair-tuning re-run**. Doing *everything* still fits inside \$250.

1. What we've done

1.1. Results & verdicts (all verified)

Study	Verdict	Key numbers
M1 attack-type-LODO (§6.5 OOD-wall prediction)	FALSIFIED at the LoRA ceiling — capacity-dependent	tfidf $T = +0.135$ (p .014) / frozen $+0.082$ (p .014) SURVIVE; lora -0.003 (p .90) FALSIFIED ; LoRA per-type AUPRC 0.956–0.984
Carrier-LODO (M2 pre-flight)	SMALL-THROUGHOUT — capacity-attenuated, residual at table	frozen $G = +0.167 \rightarrow$ lora $+0.067$ (CI-low $+0.064$; $\sim 60\%$ attenuation); per-carrier at lora: email -0.012 / code $+0.007$ / table $+0.205$
EDA geometry (pre-modeling)	carrier dominates; attack-type embedding-invisible (on frozen <i>MiniLM</i>)	silhouette by-carrier 0.197 vs by-attack-type -0.023 ; KMeans $\rightarrow$ carrier ARI 0.98 vs -0.001
Off-the-shelf detectors (V10)	consistent with scope-blindness, not undetectable data	ProtectAI AUROC 0.44 (worse than chance); Prompt-Guard-86M 0.86 attack / 0.04 benign (AUROC 0.97)
Independent audit (5 verifiers)	5/5 reproduce, $\Delta \leq 10^{-4}$, no mismatch	every headline statistic re-derived independently

1.2. The finding, scoped to its axis

On the attack-type axis, within BIPIA indirect injection, the OOD “wall” is a property of the **representation, not the task**: real for lexical / frozen-embedding detectors, and surmountable by a small amount of end-to-end capacity, which detects every held-out attack-type near-uniformly (test AUPRC **0.956–0.984**). On the carrier axis, it is only *partially* capacity-resistant — a residual wall at tabular contexts ($+0.205$, $n=3$, provisional). Across families (the prototype’s direct $\rightarrow$ indirect, cross-dataset wall), whether fair-tuned capacity climbs it is **open**.

Two caveats on “dissolved”

(a) **Ceiling-compression (a bound, not a refutation)**. At the LoRA rung the per-type AUPRCs all sit near the upper bound (0.956–0.984, well above the ~ 0.926 no-skill floor). The statistic T is a top- k minus bottom- k difference of those levels, so with everything pinned near ceiling the contrast is mechanically compressed toward zero: $T \rightarrow 0$ reflects *uniform near-ceiling detection* as much as a “dissolved” gap. This *bounds* how triumphantly we can read “dissolved” — it does *not* undermine the FALSIFIED verdict, whose rule, tails, k , and estimator were fixed before any LoRA datum and write-gated.

(b) Within-corpus. The held-out attack-type shares carrier, corpus, and generating process with the training types — this is *within-corpus* generalization, the expected easy case, not the demanding *cross-family* test.

1.3. Consistency with the pre-modeling EDA

The EDA was computed on the **frozen MiniLM** embedding (*not* the ModernBERT detector backbone), so it could only ever describe how *frozen* / *lexical* detectors behave — and the modeling confirmed it exactly there:

- The per-type prediction **SURVIVES at tfidf and frozen** (the representation it was derived from) and dissolves only at LoRA — the capacity axis the EDA was blind to by construction.
- The EDA's single biggest call was the **bullseye**: it named the *carrier* (not the attack-type) as the real wall *before any model ran*; the carrier-LODO then found exactly that residual carrier wall.
- The off-the-shelf reading (V10) held: direct-trained probes are *consistent with* scope-blindness to indirect injection (ProtectAI AUROC 0.44), while the indirect-capable probe fires (PG1 AUROC 0.97). (This is an *interpretation* of a below-chance score; the portfolio's own prescription — demonstrate it with per-row score distributions — is not yet run, hence the softened wording.)

1.3.1. Two framing corrections folded into this review

1. **S2 vs. capacity-dependence (fixed earlier this session).** An over-claim conflated the pre-registered S2 caveat (*prediction-encoder choice* MiniLM → frozen ModernBERT — the ranking *transfers*, verified at the frozen rung) with the broader, not-pre-committed *capacity* dissolution at LoRA. The two are now separated wherever they travel.
2. **Cross-family scope (this review).** An independent second-opinion audit found the review layer generalized past the within-BIPIA axes ("answered on two axes"; "property of the representation, not the task"). The boundary between what was *shown* (within-BIPIA attack-type + carrier) and what was *inherited* / *open* (the prototype's cross-family wall) is now drawn explicitly — this whole document is the corrected version.

1.4. Fine-tuning status

- **LoRA — done.** This *is* the promising result; it dissolved the attack-type wall.
- **full_ft (full fine-tune) — deliberately not run.** Its trigger-gate resolved *does-not-fire*. The *expectation* is that more capacity than LoRA can only dissolve the attack-type wall further — but note this is a **conjecture**: full-FT OOD was never measured (the prototype's attempt crashed; ADR-052/ADR-075), so it is an expectation, not a result.
- **Lane 2 (carrier-axis LoRA) — the genuine next within-BIPIA fine-tune (§2(3));** upstream-blocked.
- **Cross-family fair-tuned re-run — the genuine open fine-tune (§2, critical #1);** unblocked.

1.5. Budget & milestones

- **M0** ratified; **v0.1.0 staged + held** for account creation (the public release).
- **M1** done + pushed; **carrier-LODO** done. **M2–M7 not started**.
- **Spend** $\approx$ \$2 of the \$250 base budget. The \$100 contingency reserve is untouched.

1.6. This session's record-work (drafted, ratification-gated)

A second-opinion audit produced a punch-list of framing/record fixes (A1–A8), drafted as ratification-ready patches in `docs/planning/record-fixes-A1-A8.DRAFT.md` — *applied to no canonical file* until ratified. They scope each shown result to its axis, mark cross-family OPEN, fix two stale/record lines, and correct one prose over-round (per-type LoRA AUPRC $0.98--0.999 \rightarrow 0.956--0.984$, to match the artifact). The **ADR-055 carrier amendment** (downgrading the spine's "standing wall" to "partially capacity-resistant, provisional") remains drafted and held; its substance is in **Appendix A**. Nothing is committed (commits are user-led).

2. What we can do (the forward paths)

(★) Critical #1 — Cross-family fair-tuning re-run ~\$1–2, 2–3 days, unblocked

The audit's sharpest finding: the portfolio proved fair-tuned capacity *dissolves the attack-type wall*; the symmetric question — does fair-tuned capacity *climb the cross-family wall*? — has no clean answer, because the only cross-family fine-tune that exists is the prototype's confounded run. Re-run it *cleanly*: replicate the prototype's pooled-OOD slate (train deepset/Gandalf/Mosscap/HackAPrompt $\rightarrow$ test BIPIA/InjecAgent/JBB/XSTest/NotInject) under the portfolio's *fair per-rung tuning* (ADR-052). The prototype already holds the configs + data slate.

Why this is high-stakes, not cosmetic

Capacity climbs cross-family $\rightarrow$ unifies both repositories; "capacity-dependent" generalizes; strongest possible story. **Capacity fails cross-family** $\rightarrow$ the headline is true only on the easy within-corpus axis; *cross-family is the real standing wall* and the central claim narrows sharply. Either outcome is publishable and pre-registered.

A lightweight pre-registration skeleton is drafted at `experiments/cross-family-transfer/criteria.DRAFT.md` (both statistics named: prototype-comparable pooled-OOD AUPRC-vs-floor + AUROC anchor, *and* a cross-rung transfer-gap as the decision statistic). The paid GPU run itself stays a separate present-first go.

(1) Consolidate — write up and ship what's already proven \$0

Turn the finished result into finished outputs — *no new experiments*:

1. Apply the held **ADR-055 amendment** (Appendix A) so the record stops calling the carrier wall a “standing wall.”
2. Write the two book chapters whose results are ready — the OOD-wall story (Ch 7) and the baseline (Ch 8). (*Their outlines exist; the prose is unwritten.*)
3. Close **v0.1.0** (tag + public release).

Value: makes the audited result citable and the milestone public; resolves the open record-vs-data gap. Highest credibility-per-dollar, lowest risk. **Needs:** a ratification and a public release (your calls).

(2) Cheap-advance — a small experiment while the big one is stuck ~\$1 each, 2–3 days

- **Lane 3 (spotlighting):** does *marking* untrusted text (delimiters, or base64-encoding) — known to make the LLM itself safer — also make our **detectors** better? Inference-only; **feeds Lane 4**.
- **Lane 1b (character-injection):** do invisible characters / look-alike letters fool our detectors? (A 2025 paper fools *older* detectors ~100% of the time.) Includes a utility-aware robustness matrix.

Value: real findings (defence + robustness *breadth*) with nothing blocking them — but these are side-quests, not the core carrier or cross-family story.

(3) Lane 2 — can we TRAIN past the carrier wall? \$156–230, 4–5 weeks

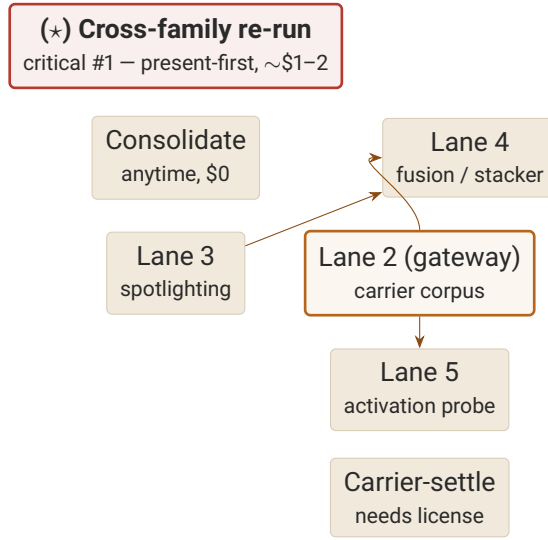
The richest within-BIPIA next step. We found a stubborn gap on **table** inputs; Lane 2 asks whether generating a big, carrier-diverse synthetic training set and retraining **closes** it.

- **Currently blocked.** The tool that generates the synthetic data has a bug that could *silently corrupt* the training set (research_toolkit #22 — §4). Options: fix it upstream first (small, drafted), use an existing corpus (cheaper, needs an agreement-quality check), or fall back to BIPIA-only data (unblocked now, but a narrower experiment).
- **The gateway.** Its training data is also what Lanes 4 and 5 need — so little downstream runs without it.
- Even a *null* result is publishable: the outcomes (data-bound / structural / worsened) were committed in advance.

(4) Carrier-settle — make the carrier finding rock-solid \$0–2, 2–3 days once licensed

Our carrier result rests on **3** container types; **2 more** (qa, abstract) sit behind a dataset license we don't have. Get the license, add them, re-run → a *settled, 5-point* finding instead of *directional, 3-point*. Cheap and quick **once licensed**, but the license is external and may not come. **Optional polish** — the current finding is already honestly flagged *provisional*, with a scheduled re-test trigger.

2.1. How they fit together



- **Cross-family re-run is the gate to the headline’s reach** — it decides whether “capacity-dependent” is a within-corpus result or a general one.
- **Lane 2 is the gate to the program’s back half** (Lanes 4 and 5 depend on its corpus).
- **Runnable now, no blocker:** Cross-family re-run, Consolidate, Lane 3, Lane 1b.
- **A sensible order:** Cross-family re-run (settle the reach) + Consolidate (bank it) → Lane 3 (cheap, feeds Lane 4) *while* pushing to unblock Lane 2 → Lane 2 → Lanes 4/5 → carrier-settle if the license appears.

2.1.1. Per-path summary

Path	Cost	Time	Blocker / gate	Adds
(*) Cross-family re-run	\$1–2	2–3 d	none (present-first)	does capacity climb the prototype’s real wall
(1) Consolidate	\$0	days	your ratify + accounts	publishable, citable result
(2) Lane 3	\$0–1	2–3 d	none	does marking help
(2) Lane 1b	\$1–3	2–3 d	none	detectors
(3) Lane 2	\$156–230	4–5 wk	upstream #22/#23 (or fallback)	char-injection robustness matrix
(4) Carrier-settle	\$0–2	2–3 d	dataset license	can training close the table wall
(5) Lane 4	\$5–30	2–3 wk	needs prior-lane scores	promotes provisional → settled
(6) Lane 5	\$10–20	2–3 d	$d' > 0.5$ gate; needs Lane-2 corpus	multi-detector fusion + frontier
(def) <code>full_ft</code>	\$2–6	~1 d	trigger says <i>don’t</i>	signal in intermediate activations
				reviewer-proofing only

3. Glossary (curated, hybrid)

Each entry: an accurate definition, then a plain-language gloss. (The repo's full docs/glossary.md has the complete set; this is the subset needed to read this review.)

Three walls / axes. The OOD “wall” is not one thing: the *attack-type* axis and the *carrier* axis live within BIPIA; the *cross-family* axis is across datasets (direct→indirect). *In plain terms*: a detector can be surprised by *what* the attack does, *where* it hides, or *which dataset* it comes from — three different surprises.

OOD (out-of-distribution). Test data from a slice not seen in training. *Plainly*: the detector is asked about something unlike anything it learned from.

LODO (leave-one-domain-out). Train on every domain but one, test on the held-out one, rotate; the domain is the attack-type (M1) or the carrier (carrier-LODO). *Plainly*: hide one category during training and check the detector still handles it.

Attack-type axis / Carrier axis. The *kind* of attack (14 BIPIA task-types) vs. the *container* it rides in (email / code / table / qa / abstract). *Plainly*: *what* the attack does vs. *where* it's hidden.

Cross-family axis. Across whole datasets: train on direct-injection corpora, test on indirect/mixed ones. The prototype's original wall. *Plainly*: the hardest surprise — a completely different source of attacks.

Capacity ladder — tfidf / frozen / LoRA / full_ft. Four detectors of increasing power: word-counts → a frozen language model's embeddings → a small fine-tune → a full fine-tune. *Plainly*: dumbest to smartest; climbing it shows whether the wall is about the *model* or the *task*.

capacity-dependent / -attenuated / residual wall. A gap that *vanishes* with model power / *shrinks but persists* / *the stubborn part left at the top*. *Plainly*: does a bigger model erase the wall, only lower it, or leave a hard core?

AUPRC vs AUROC. Two accuracy scores. AUPRC is inflated when positives are common (BIPIA carriers are 83–94% positive, so chance AUPRC ≈ 0.92); AUROC is balance-robust (0.5 = chance, below 0.5 = worse than chance). *Plainly*: AUPRC can flatter a useless detector here; AUROC tells the truth — which is why ProtectAI's 0.44 exposes it as scope-blind.

transfer-gap (T) / ROC-gap (G). The test statistics for two axes — how much detection drops on a held-out attack-type (*T*) or carrier (*G*). *Plainly*: the measured height of the wall.

SURVIVES / FALSIFIED / SMALL-THROUGHOUT. The three pre-committed verdicts: the wall is real and resists fine-tuning / is statistically gone / is real but only partly resists. *Plainly*: the wall stands, falls, or partly-stands — decided by a rule fixed in advance.

pre-registration / write-gate. Writing the hypothesis and decision rule *before* seeing data; the write-gate forbids computing the verdict until all experiments have run. *Plainly*: call your shot first, and don't peek.

permutation p / bootstrap CI. “Could this be a fluke?” (reshuffle labels) and “is it reliably above zero?” (resample). *Plainly*: two sanity checks a result must pass.

payload-clustered bootstrap. Resampling correlated groups (the ~ 5 strings per type) rather than rows. *Plainly:* don't pretend correlated examples are independent.

silhouette / ARI. Clustering-geometry scores; by-carrier 0.197 vs by-attack-type -0.023 means the data clump by container, not attack-type — **on the frozen MiniLM embedding** (not the ModernBERT detector backbone). *Plainly:* that embedding “sees” the carrier and is blind to the attack-type.

embedding-invisible. A signal absent from the frozen embedding yet learnable end-to-end. *Plainly:* the clue isn't in the model's frozen snapshot, but it can learn to see it if trained.

κ (**Cohen's kappa**). Chance-corrected annotator agreement; Lane 2 needs $\kappa \geq 0.5$ before trusting synthetic data. d' (**d-prime**). How far apart two distributions are; Lane 5's go/no-go gate (> 0.5). **PAD / MMD.** Two measures of how different the test set is from training.

S2 (encoder-transfer caveat). A pre-registered note that using one embedding model to *predict* another's behaviour might not transfer (it did, at the frozen rung) — distinct from the separate finding that *fine-tuning* erases the attack-type wall.

trigger-gate (§16) / Tier A · B · C. An “if X happens, then do Y” promise written in advance / a budget ladder (free-local / cheap-paid / expensive-gated). *Plainly:* deferring isn't dropping; expensive add-ons run only if cheaper results justify them.

spotlighting / character-injection (ASR) / activation probe. Marking untrusted text / evasion via weird characters (attack success rate) / reading internal activations to spot task-drift — Lanes 3, 1b, 5.

BIPIA / ProtectAI / Prompt-Guard. The benchmark (indirect injection across carriers $\times$ attack-types) / off-the-shelf detectors (ProtectAI + PG2 are direct-trained and scope-blind; PG1 is indirect-capable and fires).

4. Upstream blockers: research_toolkit #22 / #23

Both are OPEN and gate Lane 2's *primary* data path (`/dataset-synthesize`, the tool that makes the synthetic training corpus).

#22 (P1 — behavioral readiness). The skill shipped without the toolkit's normal post-ship “dogfood” check. Three confirmed problems (code fixes tracked in sibling issue #21):

1. **Silent-failure (the corpus-corruption risk):** the text-extraction function returns an empty string when a model response has no text block (a refusal, or a tool-only/thinking-only stop), with no warning — and that empty string gets written straight into the training corpus. The fix (raise instead of silently returning empty) is ~ 10 lines and drafted.
2. **Fail-late:** the API-key check lives only in the CLI entry point, so a programmatic caller gets a deep SDK error instead of a friendly message.
3. **No burn-in:** the skill was never exercised once against a real recipe and logged.

#23 (P2 – installability). The skill exists but isn’t wired into the toolkit’s install lists, so a fresh agent following the README **cannot invoke it**. Fix: generate the install lists from the skill files (one source of truth).

Net for Lane 2. The primary path needs #22 (especially the silent-failure fix) and #23 resolved upstream – both research_toolkit-side and user-pushed. Until then, Lane 2 either waits or uses the BIPIA-only fallback (narrower).

A. The held ADR-055 carrier amendment (draft)

This formalizes the carrier-LODO verdict into the spine decision record. **Drafted, not yet applied** – included here so the pending decision can be reviewed alongside the rest. Full draft at docs/planning/adr-055-carrier-amendment.DRAFT.md.

What changes. ADR-055 currently calls the carrier axis the “**standing wall**.” The carrier-LODO verdict (SMALL-THROUGHOUT) shows that’s too strong; the amendment rewords it to “**partially capacity-resistant (provisional, n=3 carriers) – capacity-attenuated, with a residual wall at the table carrier**,” records the result in a dated “Carrier-LODO resolution” section, and registers a §16 re-test gate (re-run at n=5 when the qa/abstract license unlocks).

The recorded resolution (verbatim core):

Verdict: SMALL-THROUGHOUT. Cross-rung gap G = mean over held-out carriers of (val ROC-AUC – test ROC-AUC): tfidf -0.156 / frozen $+0.167$ (CI-low $+0.163$) / lora $+0.067$ (CI-low $+0.064$); per-carrier at lora email -0.012 / code $+0.007$ / **table** $+0.205$. Decision rule (pre-registered): SURVIVES iff $G(\text{lora}) > 0$ **and** CI-low > 0 **and** $G(\text{lora}) \geq \frac{1}{2} G(\text{frozen})$; FALSIFIED iff CI-low ≤ 0 ; else SMALL-THROUGHOUT. Here CI-low $+0.064 > 0$ (not FALSIFIED) **and** $G + 0.067 < \frac{1}{2} \cdot 0.167 = 0.0835$ (not SURVIVES) $\Rightarrow$ SMALL-THROUGHOUT. The gap attenuates $\sim 60\%$ frozen $\rightarrow$ lora.

Resolution: the carrier “standing wall” claim is **refined, not validated and not dissolved** – partially capacity-resistant; email/code close at the LoRA ceiling, the **table** carrier keeps a substantial wall ($+0.205$). Recorded **provisional** at $n = 3$ carriers (qa/abstract license-gated); a §16 re-test gate re-fires at $n = 5$ when the license unlocks.

Open choices flagged for ratification: keep the two other in-text “standing wall” mentions as the pre-resolution record (recommended; matches the prior ADR pattern); register the re-test gate in §16 + the resolution section rather than as a new numbered Decision; carry the “(provisional, n=3)” tag on downstream mentions. *Note:* the separate audit patch **A2** (naming the three shift components in the spine) is to be ratified *alongside* this amendment – both touch ADR-055.

Sources: *experiments/{eda/OOD_WALL_PREDICTION, carrier-lodo, AUDIT_2026-06}/; decisions/ADR-05{2,4,5}-*.md, contingency_unlock_1.md, upstream_issues.md; docs/planning/{prototype-comparison-audit-2026-06.md, PORTFOLIO_PLAN.md, forward-paths-explained.md}; docs/glossary.md*. Every number traces to a persisted artifact or git history; corrections folded in from the 2026-06-02 second-opinion audit.